Phase D: Secret Lifecycle Analysis

Objective: map the lifecycle of potential exposed secrets and propose mitigations for creation, storage, usage, rotation and revocation.

Evidence status

No valid, active credential leak has been confirmed. This report separates observed scanner evidence from conditional risk scenarios. Creation source, actual usage, rotation policy and revocation status remain unknown for the reviewed detections.

Phase C evidence used

TruffleHog 3.99.7 reported 13,519 unverified detections in the SecLists Git history. Verification was disabled. The scan reached its completion message after 27 minutes, 33 seconds. A timeout on Payloads/Zip-Bombs/42-passwordless.zip limits coverage of that archive. Gitleaks completion remains unconfirmed.

Selected detections

Eraser: flarum.txt and flarum-all-levels.txt

YoutubeApiKey: shopware.txt and shopware-all-levels.txt

Directory: Discovery/Web-Content/CMS/trickest-cms-wordlist/

Seven supplied detection records span four files, with repeated detector/file combinations across commits. They are not established as seven unique secrets.

Context and lifecycle assessment

Samples from current Flarum and Shopware files contain filenames and directory paths, consistent with CMS discovery wordlists. This suggests possible false positives; the exact historical matched values were not reviewed.

Storage: historical Git repository paths. Creation source: unknown. Usage: not established. Rotation policy: not established. Revocation: unknown. Validity: unverified.

Historical references supplied

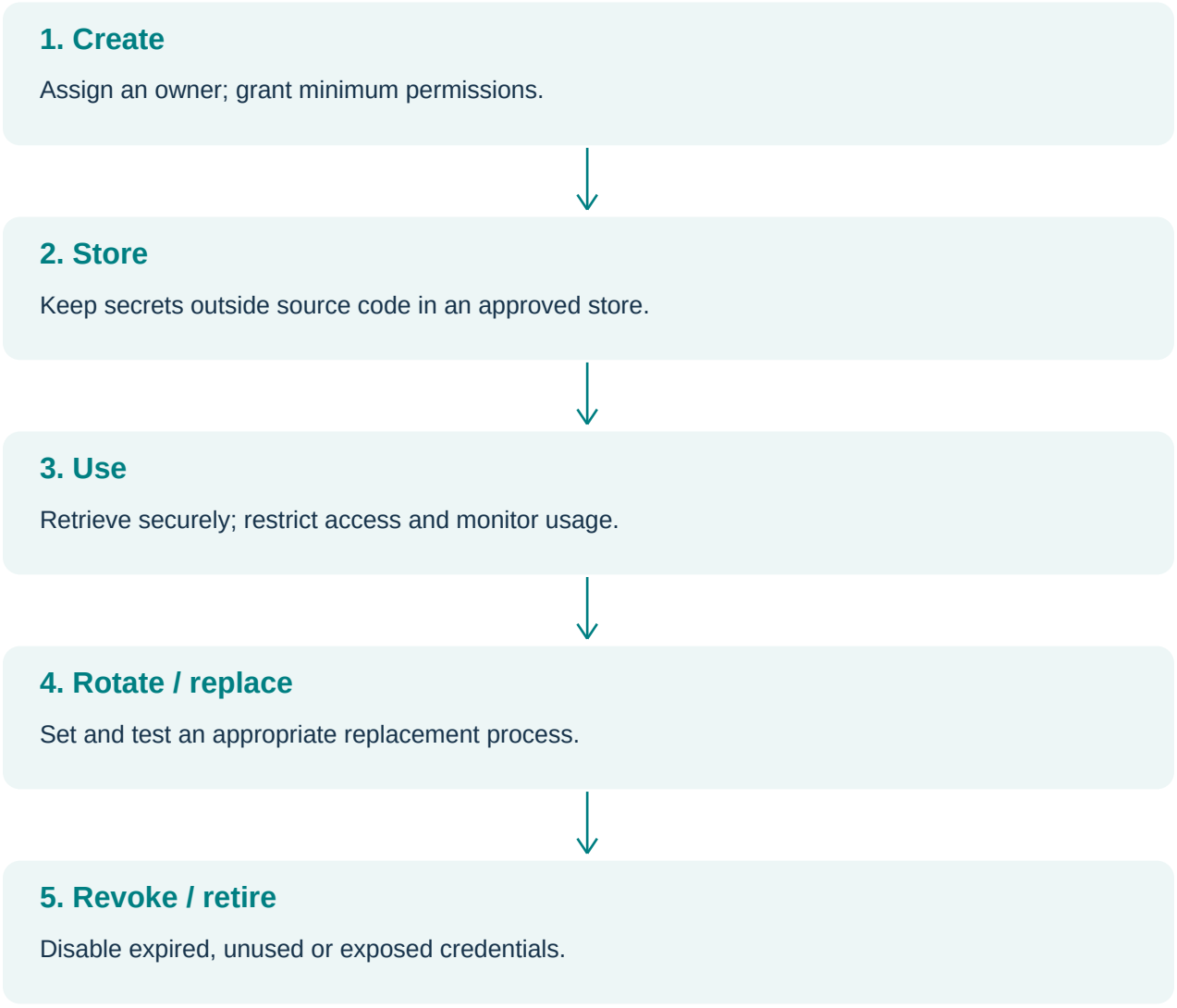
3fdb381e424fba5a95a3ed6594b39db5aa217d05

0b964a69bdd1ffdd780a7978eb91ac1ca432dcb6

959a76a92667359ffa20229a1eb3f6eac990ad8e

Recommended Lifecycle

Figure 1. Proposed controls, not an observed lifecycle of the detected values.



Exposure response applies at every stage

Suspected exposure -> investigate promptly -> revoke or disable a confirmed affected credential -> replace if needed -> review logs -> remove exposed copies and correct the cause.

Routine replacement returns to secure storage and usage. For AWS workloads, prefer temporary role credentials where supported. Deleting a value from the latest commit does not revoke it or remove historical copies.

Risk Matrix and Recommendations

Ratings are illustrative assumptions for potential scenarios, not measured ratings for the supplied unverified findings. Likelihood and impact: Low = 1, Medium = 2, High = 3. Score = likelihood x impact; 1-2 Low, 3-4 Medium, 6-9 High.

Conditional scenario	L	I	Score
Valid unrestricted API key committed publicly	2	3	6 / High
Valid credential remains usable in Git history	2	3	6 / High
Repeated test-data matches obscure a real exposure	3	2	6 / High

Mitigations matched to risks

1. Public API-key exposure: revoke or replace confirmed exposed keys; restrict APIs and authorized applications where supported; apply quotas and monitor use. Impact depends on actual permissions and restrictions.

2. Historical exposure: revoke first, then address Git history and other copies. Use temporary IAM roles for AWS workloads where supported; apply least privilege. Store required application secrets in Secrets Manager or encrypted Parameter Store parameters, with restricted retrieval and encryption-key access.

3. Review overload: deduplicate findings and inspect exact matches at recorded commits. Introduce scanning before commits and in CI/CD. Add narrowly scoped exclusions only for confirmed test data.

For every managed secret, record its owner, intended use, approved storage, replacement schedule and revocation procedure. Secret storage alone does not establish rotation.

Outstanding work

Review exact historical matches, confirm Gitleaks completion and validate its JSON report. Reassess risks if genuine exposures are established. This report provides a proposed lifecycle and three rated scenarios; it does not claim analysis of confirmed valid secrets.

Official reference points

docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html

docs.aws.amazon.com/secretsmanager/latest/userguide/intro.html

docs.aws.amazon.com/systems-manager/latest/userguide/systems-manager-parameter-store.html